Cybersecurity standards European approach

Udo Helmbrecht

SECURE 2015| Warsaw | 15th October 2015

European Union Agency for Network and Information Security

Positioning ENISA activities

ENISA Art.14 requests
Situation since 2011

- 44 Requests for Advice & Assistance closed
  - 18 Member States
  - EC, EEAS, EDPS, Council, EP
- 18 Inquiries answered
- 16 Requests ongoing
- 4 Polish requests
  - 2012: ENISA involvement in the Polish exercises
  - 2014: Honeynet Project workshop
  - 2015: Building Polish cybersecurity governance model
  - 2016: Training national Police

Cyberspace

> **“A consensual hallucination experienced daily by billions of legitimate operators, in every nation, by children being taught mathematical concepts... A graphic representation of data abstracted from the banks of every computer in the human system. Unthinkable complexity. Lines of light ranged in the nonspace of the mind, clusters and constellations of data. Like city lights, receding.”**

Wiliam Gibson
***Neuromancer* (1984)**

Cybersecurity

> *Measures taken to protect a computer or computer system (as on the Internet) against unauthorized access or attack*

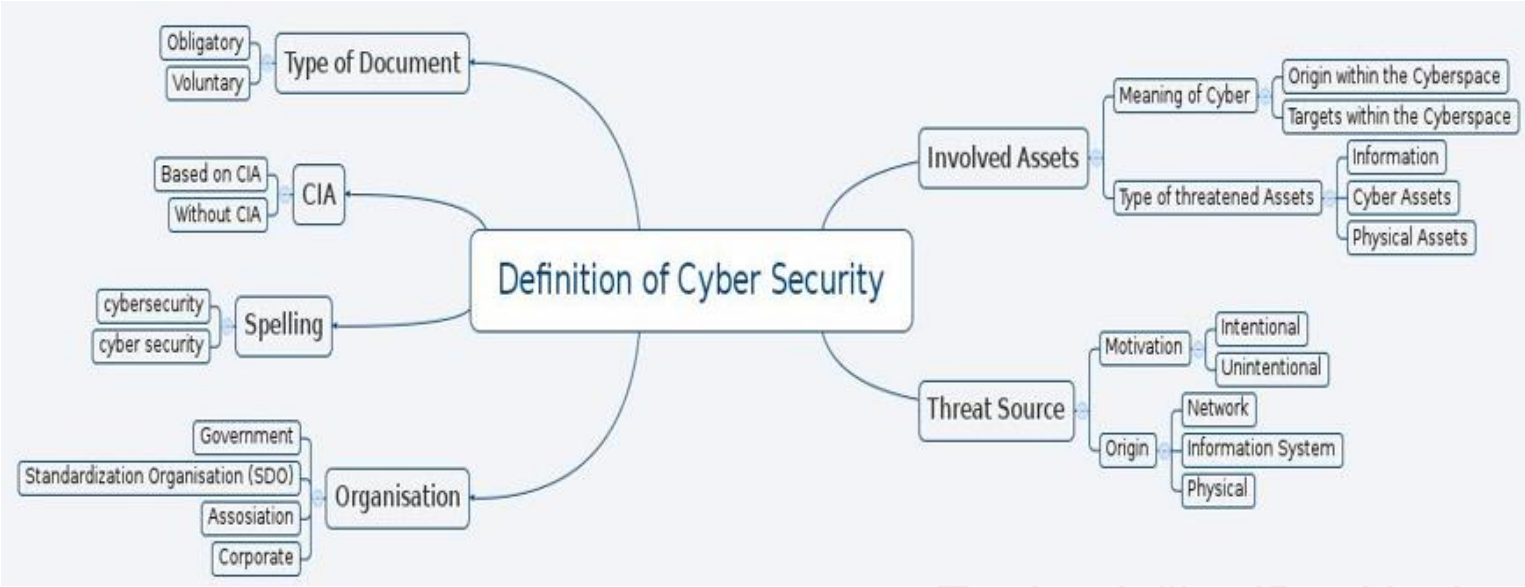
Merriam Webster

> *The state of being protected against the criminal or unauthorized use of electronic data, or the measures taken to achieve this*

Oxford English (Oxford University Press)

What is ‘Cybersecurity’?

- Security, safety and privacy often been used as synonyms
- Young term, crafted by IT professionals, consultants, lobbyists and politics to address security concerns in the ‘Cyber Space’
- Complicity of Cybersecurity



REGULATION (EU) 1025/2012 – Definition of standard

REGULATION (EU) No 1025/2012 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 25 October 2012 on European standardisation, amending Council Directives 89/686/EEC and 93/15/EEC and Directives 94/9/EC, 94/25/EC, 95/16/EC, 97/23/EC, 98/34/EC, 2004/22/EC, 2007/23/EC, 2009/23/EC and 2009/105/EC of the European Parliament and of the Council and repealing Council Decision 87/95/EEC and Decision No 1673/2006/EC of the European Parliament and of the Council

Definition of standard

(1) **'standard' means** a technical specification, adopted by a recognised standardisation body, for repeated or continuous application, with which compliance is not compulsory, and which is one of the following:

(a) 'international standard' means a standard adopted by an international standardisation body;

(b) 'European standard' means a standard adopted by a European standardisation organisation;

(c) 'harmonised standard' means a European standard adopted on the basis of a request made by the Commission for the application of Union harmonisation legislation;

(d) 'national standard' means a standard adopted by a national standardisation body;

REGULATION (EU) No 1025/2012 – Standardisation bodies

(8) **'European standardisation organisation'** – an organisation listed in Annex I:

Annex I - EUROPEAN STANDARDISATION ORGANISATIONS

1. CEN – European Committee for Standardisation
2. Cenelec – European Committee for Electrotechnical Standardisation
3. ETSI – European Telecommunications Standards Institute

(9) **'international standardisation body'** means the International Organisation for Standardisation (ISO), the International Electrotechnical Commission (IEC) and the International Telecommunication Union (ITU)

Plethora of SDOs dealing with Cybersecurity

Cybersecurity areas covered by standardisation

- Security feature provision
  - Provision of sector/technology specific security features.
- Security assurance
  - Common Criteria (ISO 15408)
  - Ongoing work in 3GPP
- Security threat sharing
  - Sharing of threat information, current attack patterns, software vulnerabilities
- Organisational management for secure operations
  - ISO 27000 series

Stakeholders of Cybersecurity standardisation

- Policy and administration
  - Maintaing relation between standards and related regulation
- Industry and research
  - Maintaining relation between standards and their products and services
- Consumers
  - Represented by consumer organisations
- Education
  - Standards treating education and training
  - Closely related to research

Challenges from EU perspective

- Lack of consistent strategy towards standards
- Recognized shortcomings of the current approach
- Need establishing a small number of key initiatives at EU level
- Improve coordination between EU funded R&D and SDOs
- Possible ‘vehicles’ for such a coordination:
  - ETSI CEN CENELEC CSCG
  - Horizon 2020

Objectives of coordinated approach towards standardisation

- Cybersecurity standards should be developed through consensus
- Cybersecurity standards should be approved in a recognized body
- The distribution of mandated work for the development of cybersecurity standards should be coordinated by the recognized bodies
- Recognized bodies should make their development work programme public and coordinate with other recognized bodies to eliminate duplication and to minimize overlap.

European Cybersecurity standardisation governance

- Europan Standardisation Organisations
  - CEN
  - CENELEC
  - ETSI
- European Commission
- DG Connect – responsible for Digital Single Market -
- DG Home – responsible for European Agenda on Security
- DG Justice – responsible for Cyber crime
- DG Growth – responsible for standardisation
- Regulation 1025/2012 on standardisation

Regulation (EU) 1025/2012 on standardisation

- Key role of the European Commission
- Planning phase
  - EU Work Programme for standardisation
- Implemenation phase
  - Consultation with relevant stakeholders
  - Approval of the Committee on Standards
  - Standardisation Requests to ETSI, CEN, CENELEC
- European SDOs after accepting trequest develop standards in a defined time frame
- Voluntary adoption of standards
- Mandatory transposition of European Norms (superceding existing national ones)

ENISA and standards

Regulation (EC) 460/2004

Art. 3 – In order to ensure that the scope and objectives set out in Articles 1 and 2 are complied with and met, the Agency shall perform the following tasks:

(g): to track the development of standards for products and services on network and information security

However

(12) The exercise of the Agency's tasks should not interfere with the competencies and should not pre-empt, impede or overlap with the relevant powers and tasks conferred on:

the European standardisation bodies, the national standardisation bodies and the Standing Committee as set out in Directive 98/34/EC of the European Parliament and of the Council of 22 June 1998 laying down a procedure for the provision of information in the field of technical standards and regulations and of rules on Information Society Services

ENISA and standards

Regulation 526/2013, Art.3.1d

Support research and development and standardisation, by:

(i) facilitating the establishment and take-up of European and international standards for risk management and for the security of electronic products, networks and services;

(ii) advising the Union and the Member States on research needs in the area of network and information security with a view to enabling effective responses to current and emerging network and information security risks and threats, including with respect to new and emerging information and communications technologies, and to using risk-prevention technologies effectively;

ENISA approach to standards

- Aim: promotion of best practices through SDOs
- ENISA role: interface between private sector, public sector, SDOs
- Short- and mid-term goals
  - Formal cooperation with SDOs and specific WGs
  - Working collaboration with SDOs
- Long-term goals
  - Review of and participation in NIS standardisation activities
  - Proposal of standards, via means of proposals for standardisation requests

ENISA and SDOs

Established collaboration agreements with:

- ISO SC27 (Liaison)
- ETSI (MoU)
  - Exchange of information of mutual interest
  - Organisation of joint meetings and workshops
  - ENISA to channel standardisation activities to ETSI, if appropriate
  - Exchange of working documents, within well defined frames
  - ENISA to nominate observers for ETSI Technical Bodies
- CEN CENELEC (MoU)
- ITU (MoU started)
- ENISA aligns key activities with the work of SDOs
  - ETSI TISPAN on CIIP, ESI on eID, CLOUD on cloud certification
  - CEN CENELEC on smart grids;
  - ISO SC 27 in the area of privacy
- ENISA is an active member of CSCG

ETSI CEN-CENELEC Cyber Security Coordination Group (CSCG)

- Give strategic advice to the technical committees of CEN, CENELEC and ETSI
- Develop a gap analysis of European and International Standards on cyber security
- Define of joint European requirements for European and International Standards on cyber security
- Establish a European roadmap on standardization of cyber security
- Act as contact point for all questions of EU institutions relating to standardization of cyber security
- Suggest a joint US and European strategy for the establishment of a framework of International standards on cyber security

CSCG Action Plan

#1 – Governance Framework

#2 – Common Understanding Of “Cyber Security”

#3 – Trust In The European Digital Environment

#4 – European Pki And Cryptographic Capabilities

#5 – European Cyber Security Label

#6 – European Cyber Security Requirements

#7 – European Cyber Security Research

#8 – Eu Industrial Forum On Cyber Security Standards

#9 – Eu Global Initiative On Cyber Security Standards

ENISA deliverables 2015

- Definition of Cybersecurity
  - Organisations involved in Cybersecurity standardization
  - Areas covered by standardisation
  - Gaps and overlaps in standardisation
- Governance framework of the European standardisation
  - How to align Policy, Industry and Research
- Security and privacy standardization for the SME community
  - List of existing ICT S&P standards that can be used by SMEs
  - Main conclusions of surveys on the status of standardization for SMEs
  - Recommendations on how to increase the adoption of ICT S&P standards in SMEs

Thank you

PO Box 1309, 710 01 Heraklion, Greece

Tel: +30 28 14 40 9710

info@enisa.europa.eu

www.enisa.europa.eu